

RAPPORT DE TEST D'INTRUSION

Beach Bar

Évaluation de sécurité d’une application web et de son hôte Linux

Environnement	TryHackMe — Beach Bar (laboratoire autorisé)
Cible observée	10.128.157.21 — adresse dynamique du laboratoire
Référentiel	Penetration Testing Execution Standard (PTES)
Date du test	18 août 2026
Testeur	dimisan221
Version	1.0 — rapport initial

CLASSIFICATION Ce rapport contient des informations techniques sensibles. Sa diffusion doit être limitée aux personnes autorisées.

Rapport établi à partir du write-up et des preuves fournies.

Contrôle du document

Historique des versions

Version	Date	Auteur	Description
1.0	27/08/2026	dimisan221	Création du rapport PTES à partir du write-up Beach Bar

Destinataires

Destinataire principal : propriétaire de l'environnement de laboratoire / évaluateur pédagogique. Toute autre diffusion doit être autorisée.

Hypothèses et informations manquantes

Le write-up ne contient pas de lettre d'autorisation, de fenêtre de test, de contacts d'urgence, de liste d'exclusions ni de critères d'arrêt. Ces éléments sont indispensables dans un engagement réel et doivent être complétés avant toute intervention sur un système de production.

PORTÉE DU RAPPORT Les conclusions reposent exclusivement sur les actions et preuves visibles dans le write-up. Aucun test complémentaire n'a été exécuté contre la cible.

Table des matières

- 1. Synthèse exécutive
- 2. Contexte, périmètre et règles d'engagement
- 3. Méthodologie PTES
- 4. Résultats techniques et chaîne d'attaque
- 5. Fiches de vulnérabilités
- 6. Plan de remédiation priorisé
- 7. Conclusion
- Annexe A. Preuves techniques
- Annexe B. Références

1. Synthèse exécutive

L'évaluation a mis en évidence une chaîne d'attaque complète permettant à un attaquant distant de passer d'un accès non authentifié à une exécution de commandes sur le serveur, puis d'obtenir les privilèges root. Le risque global est évalué comme critique.

CONSTAT PRINCIPAL Des identifiants divulgués dans le code HTML donnent accès à une fonction d'import YAML vulnérable. La désérialisation non sécurisée permet une exécution de commandes, puis un mot de passe exposé dans les arguments d'un processus permet une élévation de privilèges jusqu'à root.

Vue d'ensemble des risques

ID	Constat	Sévérité	Effet principal
BB-01	Identifiants divulgués dans les commentaires HTML	Moyenne	Accès non autorisé à l'interface
BB-02	Désérialisation YAML non sécurisée	Critique	Exécution de commandes à distance
BB-03	Secret exposé dans la ligne de commande d'un processus	Élevée	Divulgence d'un mot de passe
BB-04	Réutilisation d'un secret privilégié / contrôles root insuffisants	Élevée	Compromission complète de l'hôte

Impact métier et technique

- Confidentialité : lecture potentielle des données accessibles au service et au compte root.
- Intégrité : modification possible de l'application, de sa configuration et du système d'exploitation.
- Disponibilité : arrêt ou altération des services avec les privilèges root.
- Traçabilité : l'utilisation d'identifiants partagés ou exposés réduit la capacité d'attribution des actions.

2. Contexte, périmètre et règles d'engagement

2.1 Objectif

L'objectif était d'identifier un chemin d'accès au drapeau utilisateur, puis au drapeau root, dans l'environnement Beach Bar. Dans un contexte professionnel, ces objectifs correspondent à la validation de l'accès initial, de l'exécution de code et de l'impact maximal d'une compromission.

2.2 Périmètre observé

Élément	Valeur
Hôte	10.128.157.21 (adresse de laboratoire observée pendant le test)
Services détectés	TCP/22 SSH ; TCP/80 HTTP
Application	Beach Bar / juke-box web
Système	Hôte Linux ; compte applicatif bartender ; compte root
Type de test	Boîte noire guidée par les éléments découverts

2.3 Règles d'engagement

Le caractère autorisé du laboratoire TryHackMe est établi par le contexte fourni. Pour un engagement réel, les règles suivantes doivent être validées par écrit avant le test :

- autorisation et propriétaire légal des actifs ;
- adresses et applications incluses ou exclues ;
- horaires, contacts d'urgence et procédure d'arrêt ;
- techniques autorisées, limites de charge et traitement des données ;
- conditions de conservation, de chiffrement et de destruction des preuves.

2.4 Limites

Le write-up ne documente pas de recherche exhaustive de vulnérabilités, de test de déni de service, de persistance, de mouvement latéral, de nettoyage détaillé ni de contre-test après correction. L'absence de constat dans ces domaines ne signifie donc pas absence de vulnérabilité.

3. Méthodologie PTES

Le rapport suit les sept phases du Penetration Testing Execution Standard. La profondeur de chaque phase est adaptée aux informations disponibles dans le write-up.

Phase	PTES	Application au test Beach Bar
1	Pré-engagement	Périmètre de laboratoire identifié ; règles formelles non fournies.
2	Collecte de renseignements	Scan Nmap et identification des services SSH et HTTP.
3	Modélisation des menaces	Priorisation de l'application web, de l'import YAML et des secrets.
4	Analyse des vulnérabilités	Validation de la fuite d'identifiants et de la désérialisation dangereuse.
5	Exploitation	Commande id, puis obtention d'un reverse shell.
6	Post-exploitation	Énumération des processus et élévation jusqu'au compte root.
7	Rapport	Qualification des risques, preuves et recommandations.

3.1 Échelle de sévérité

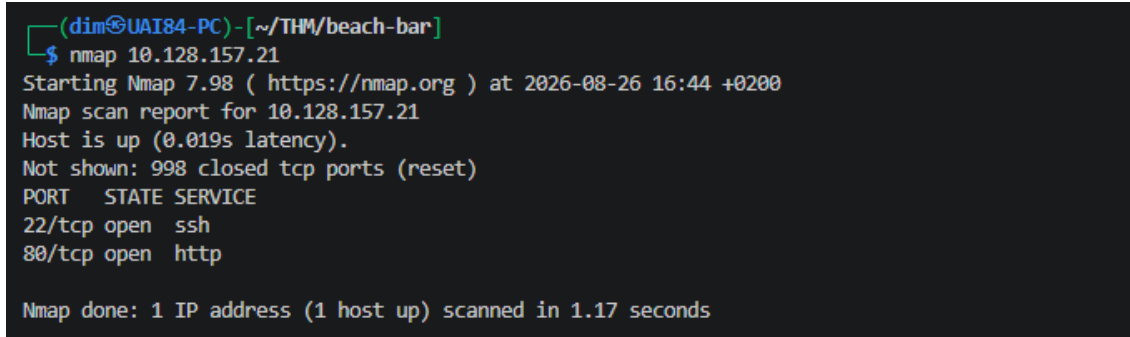
La sévérité combine exploitabilité, impact technique et conséquence opérationnelle. Les scores CVSS proposés sont indicatifs : un calcul définitif doit être validé avec le contexte métier et l'architecture réelle.

Niveau	Interprétation
Critique	Compromission complète ou chaîne d'attaque menant directement à un impact majeur.
Élevée	Impact important, notamment élévation de privilèges ou exposition de secrets sensibles.
Moyenne	Faiblesse exploitable dont l'impact dépend d'une étape complémentaire.
Faible	Impact limité ou conditions d'exploitation contraignantes.

4. Résultats techniques et chaîne d'attaque

4.1 Reconnaissance

Un scan réseau a identifié deux services exposés : SSH sur le port 22 et HTTP sur le port 80. L'application web a été retenue comme principal point d'entrée, car elle présentait une surface d'attaque directement accessible.



```
(dim@UAI84-PC) - [~/THM/beach-bar]
$ nmap 10.128.157.21
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-26 16:44 +0200
Nmap scan report for 10.128.157.21
Host is up (0.019s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 1.17 seconds
```

Figure 1 — Découverte des ports TCP/22 et TCP/80 avec Nmap.

4.2 Accès à l'application

La page web demandait une authentification. L'examen du code côté client a révélé des informations d'identification laissées dans un commentaire HTML. Ces données ont permis de franchir le contrôle d'accès.

4.3 Identification de la surface YAML

Après authentification, l'interface permettait d'importer et d'exporter des listes de lecture au format YAML. Ce mécanisme constituait une surface d'attaque sensible, car le contenu fourni par l'utilisateur était transformé en objets Python côté serveur.

4.4 Exploitation de la désérialisation

Une charge utile YAML utilisant un tag Python a exécuté la commande `id`. Ce test de validation, volontairement limité, a confirmé l'exécution de commandes système. La charge a ensuite été adaptée pour provoquer une connexion inverse vers la machine du testeur.

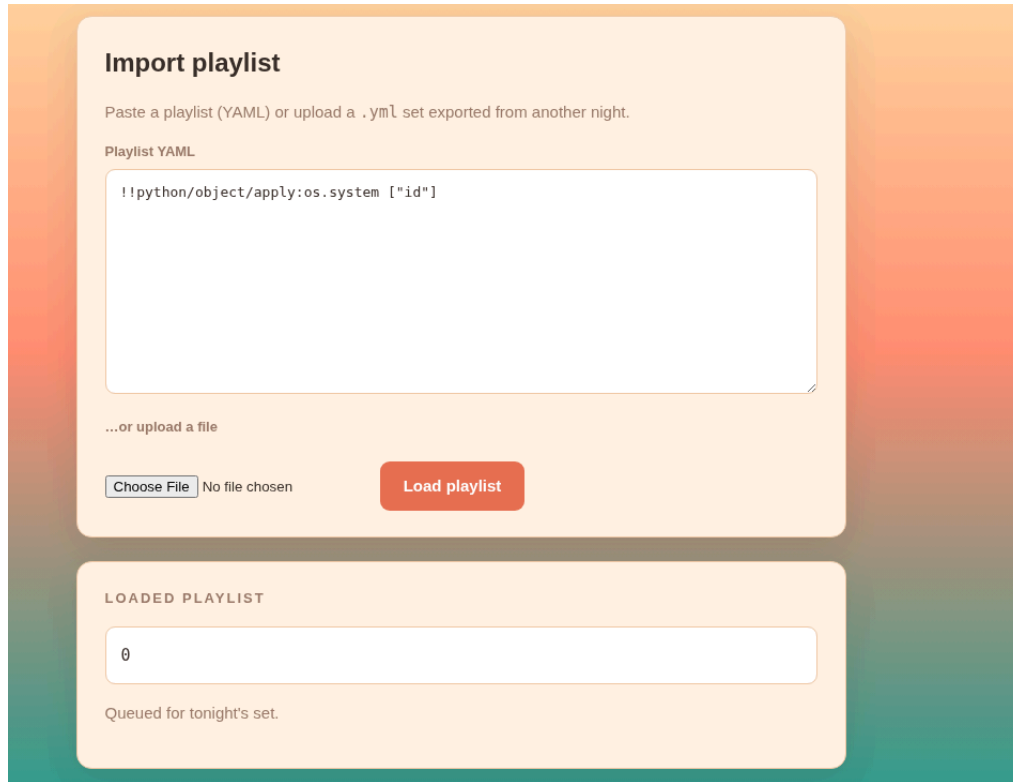


Figure 2 — Validation de l'exécution de la commande `id` via un document YAML malveillant.

La réception du reverse shell a fourni un accès interactif avec le compte applicatif `bartender`. Le drapeau utilisateur a alors été localisé dans les fichiers accessibles.

```
(dim@UAI84-PC) - [~/THM/beach-bar]
$ nc -lvnp 666
listening on [any] 666 ...
connect to [192.168.145.73] from (UNKNOWN) [10.128.151.225] 53660
bash: cannot set terminal process group (611): Inappropriate ioctl for device
bash: no job control in this shell
bartender@tryhackme-2404:/opt/beach-bar/webapp$ ls
```

Figure 3 — Réception du reverse shell avec le compte applicatif `bartender`.

4.5 Post-exploitation et élévation de privilèges

L'énumération des processus liés au juke-box a révélé un argument `--stream-pass` contenant un secret en clair. Le secret a pu être réutilisé avec la commande `su` pour obtenir une session root. Cette étape démontre une compromission totale de l'hôte.

```

[diu@UA194-PC] ~/THW/beach-bar
$ nc -lvp 666
listening on [any] 666 ...
connect to [192.168.145.73] from (UNKNOWN) [10.130.172.223] 57392
bash: cannot set terminal process group (620): Inappropriate ioctl for device
bash: no job control in this shell
bartender@tryhackme-2484:/opt/beach-bar/webapp$ ps aux | grep jukebox
ps aux | grep jukebox
root        619    0.0  0.2 20176 11772 ?        Ss   12:05   0:00 /opt/beach-bar/venv/bin/python /opt/beach-bar/jukeboxd/jukeboxd.py --stream-pass SunsetSprint2024! --bitrate 320k
bartend+   1218    0.0  0.0  7084  2240 ?        S    12:09   0:00 grep --color=auto jukebox

```

Figure 4 — Secret visible dans les arguments du processus juke-box.

4.6 Chaîne d'attaque validée

1. Découverte de l'application web exposée sur le port 80.
2. Récupération d'identifiants dans un commentaire HTML.
3. Accès à la fonction d'import YAML.
4. Exécution de commandes via désérialisation non sécurisée.
5. Obtention d'un reverse shell sous le compte bartender.
6. Lecture d'un secret dans la ligne de commande du processus juke-box.
7. Réutilisation du secret et obtention des privilèges root.

5. Fiches de vulnérabilités

BB-01 — Identifiants divulgués dans les commentaires HTML

SÉVÉRITÉ MOYENNE CWE-615 — Inclusion d'informations sensibles dans les commentaires du code source.
CVSS indicatif : 5.3 (à confirmer selon le contexte).

Description

Des informations d'authentification étaient présentes dans un commentaire HTML transmis au navigateur. Un utilisateur non authentifié peut consulter ce contenu avec les outils de développement ou le code source de la page.

Impact

La faiblesse permet de contourner la confidentialité attendue des identifiants et d'accéder aux fonctions réservées de l'application. Dans cette chaîne d'attaque, elle rend accessible l'import YAML vulnérable.

Recommandations

- Supprimer immédiatement tout identifiant, secret ou information opérationnelle des commentaires et ressources côté client.
- Révoquer les secrets exposés et créer des comptes nominatifs avec des mots de passe uniques.
- Ajouter une détection de secrets dans le dépôt, la chaîne CI/CD et les revues de code.
- Vérifier que l'authentification et les autorisations sont appliquées exclusivement côté serveur.

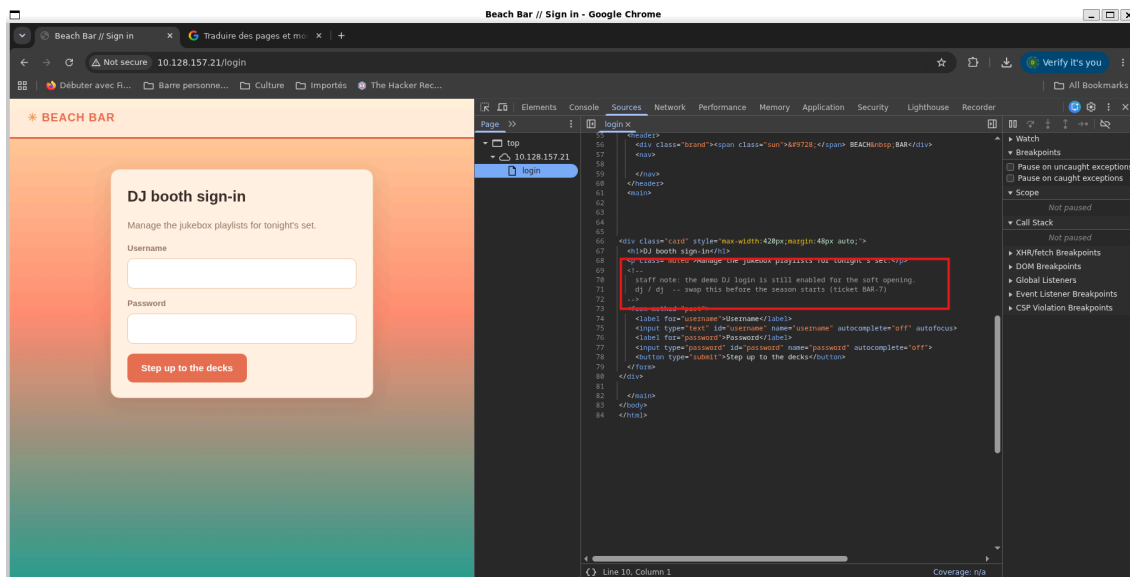


Figure 5 — Commentaire HTML contenant des informations d'authentification.

BB-02 — Désérialisation YAML non sécurisée

SÉVÉRITÉ CRITIQUE CWE-502 — Désérialisation de données non fiables. CVSS v3.1 indicatif : 8.8 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H) ; risque global critique dans la chaîne observée.

Description

Le serveur accepte un document YAML contrôlé par l'utilisateur et le désérialise avec une fonction autorisant la construction d'objets Python dangereux. Le tag `!!python/object/apply:os.system` provoque l'appel d'une commande système.

Preuve et reproductibilité

L'import d'une charge exécutant `id` a confirmé l'exécution de code. Une seconde charge a établi une connexion inverse vers le testeur. La vulnérabilité est donc reproductible et conduit à un accès système distant.

Impact

Un attaquant authentifié peut exécuter des commandes avec les droits du service, lire ou modifier ses données, détourner l'application et préparer une élévation de privilèges. Combinée aux autres faiblesses, l'exploitation conduit à root.

Recommandations

- Utiliser un chargeur YAML sûr, par exemple `safe_load`, et interdire les tags Python personnalisés.
- Valider le schéma attendu avec une liste stricte de champs, de types et de tailles autorisés.
- Traiter les fichiers importés comme non fiables et isoler leur traitement dans un composant faiblement privilégié.
- Ajouter des tests automatisés vérifiant le rejet des tags `!!python/*` et des objets inattendus.
- Journaliser les erreurs d'import sans exposer de détails internes à l'utilisateur.

BB-03 — Secret exposé dans les arguments d'un processus

SÉVÉRITÉ ÉLEVÉE CWE-214 — Informations sensibles dans les arguments d'une commande. Le secret est lisible lors de l'énumération locale des processus.

Description

Le processus du juke-box est lancé avec un secret transmis par l'option `--stream-pass`. Selon les permissions du système, les arguments des processus peuvent être consultés par d'autres utilisateurs locaux via `ps` ou `/proc`.

Impact

Tout utilisateur ayant obtenu un accès local peut récupérer le secret. Dans le scénario observé, ce secret a servi de pivot vers un compte privilégié.

Recommandations

- Ne jamais transmettre de secret en argument de ligne de commande.
- Stocker le secret dans un gestionnaire de secrets et le fournir au processus par un mécanisme contrôlé.
- Restreindre la visibilité des processus entre utilisateurs lorsque le système le permet.
- Effectuer une rotation immédiate du secret divulgué et rechercher sa réutilisation.

BB-04 — Réutilisation d'un secret privilégié

SÉVÉRITÉ ÉLEVÉE Le même secret ou un secret équivalent permet l'authentification du compte root. L'impact final est une compromission totale de l'hôte.

Description et impact

Le secret récupéré depuis le processus a été accepté par su pour le compte root. Cette réutilisation transforme une compromission applicative en compromission complète du système et révèle une séparation insuffisante entre secrets applicatifs et administratifs.

Recommandations

- Attribuer un secret unique et aléatoire à chaque usage ; interdire toute réutilisation avec un compte système.
- Désactiver l'authentification directe du compte root lorsque cela est possible et utiliser sudo avec des comptes nominatifs.
- Appliquer le principe du moindre privilège au compte du service et limiter ses capacités d'énumération.
- Surveiller les tentatives su/sudo et les changements de contexte vers root.

6. Plan de remédiation priorisé

Priorité	Délai conseillé	Action	Résultat attendu
P0	Immédiat	Désactiver l'import YAML vulnérable ou le remplacer par un chargeur sûr.	Suppression du vecteur RCE.
P0	Immédiat	Révoquer tous les secrets exposés et changer le secret root.	Blocage de la chaîne connue.
P1	7 jours	Supprimer les identifiants des commentaires et auditer les ressources web.	Réduction des fuites côté client.
P1	7 jours	Retirer les secrets des arguments de processus et utiliser un coffre-fort.	Protection des secrets locaux.
P1	14 jours	Désactiver l'accès direct root ; déployer sudo nominatif et journalisé.	Meilleure séparation des privilèges.
P2	30 jours	Ajouter validation de schéma, tests de sécurité et détection de secrets CI/CD.	Prévention durable des régressions.
P2	Après correction	Réaliser un contre-test ciblé de la chaîne complète.	Validation de l'efficacité des corrections.

6.1 Critères de contre-test

- Aucun identifiant ni secret n'est présent dans les réponses HTTP, commentaires ou fichiers JavaScript.
- Les tags YAML dangereux sont rejetés sans exécution de commande ni erreur détaillée côté client.
- Les arguments des processus ne contiennent plus de secret exploitable.
- Le secret applicatif ne permet aucune authentification système ou élévation vers root.
- Le compte de service ne dispose que des droits nécessaires au fonctionnement du juke-box.

7. Conclusion

Le test a démontré qu'une succession de faiblesses — fuite d'identifiants, désérialisation YAML dangereuse, exposition d'un secret et réutilisation de ce secret — permet de compromettre entièrement l'hôte Beach Bar. La priorité doit être donnée à la suppression de l'exécution de code et à la rotation des secrets, puis au renforcement de l'authentification, de la gestion des privilèges et du cycle de développement sécurisé.

RISQUE RÉSIDUEL Le risque reste critique tant que la désérialisation non sécurisée et les secrets exposés ne sont pas corrigés et contre-testés.

Annexe A — Preuves techniques complémentaires

Les captures ci-dessous proviennent du write-up fourni. Elles sont conservées comme éléments de preuve du déroulement observé.

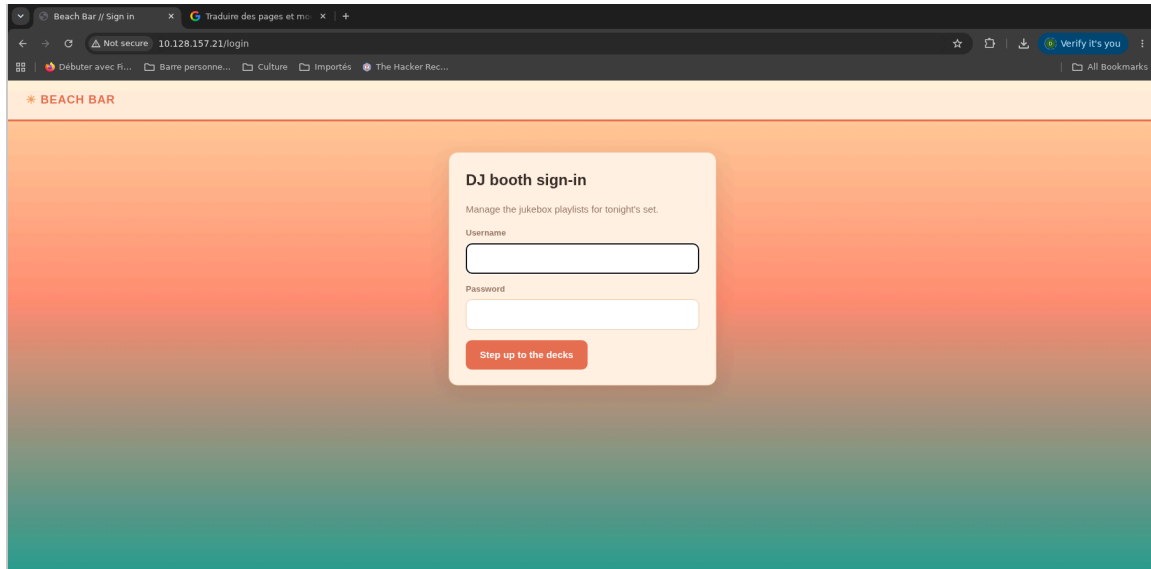


Figure A1 — Page d'authentification exposée sur le service HTTP.

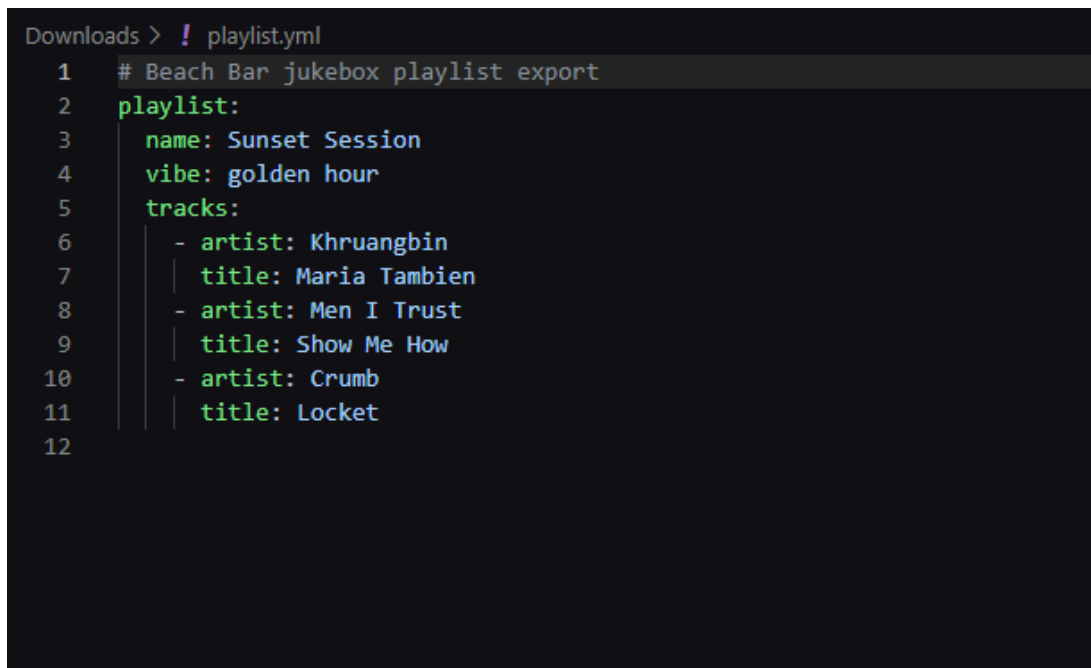


Figure A2 — Fichier de liste de lecture YAML exporté par l'application.

Annexe B — Références

Penetration Testing Execution Standard (PTES), sections principales et lignes directrices techniques :
<https://www.pentest-standard.org/>

MITRE CWE-502 — Deserialization of Untrusted Data.

MITRE CWE-615 — Inclusion of Sensitive Information in Source Code Comments.

MITRE CWE-214 — Invocation of Process Using Visible Sensitive Information.

FIRST — Common Vulnerability Scoring System v3.1 Specification.

Annexe C — Précautions de lecture

Les commandes, adresses et secrets visibles sont issus d'un laboratoire pédagogique. Ils ne doivent pas être réutilisés contre un système sans autorisation explicite. Les scores et sévérités sont des estimations destinées à soutenir la priorisation ; ils doivent être recalibrés avec le contexte métier réel.